Descrizione delle azioni di una minaccia

Description

TTPs: Tattiche, Tecniche e Procedure

- **Tattiche (Tactics)** → Il "perché": rappresentano gli obiettivi che un attaccante vuole raggiungere in una fase dell'attacco.
- **Tecniche (Techniques)** → Il "come": descrivono i vari metodi per raggiungere un determinato obiettivo tattico.
- **Procedure (Procedures)** → Il dettaglio tecnico: rappresentano l'implementazione specifica della tecnica.

MITRE ATT&CK

Framework che organizza le TTPs e include anche tecniche di mitigazione. Tuttavia, non fornisce direttamente una sequenza strategica di un attacco.

Le 14 Tattiche del MITRE ATT&CK

1. **Reconnaissance:** Raccolta di informazioni per pianificare intrusioni future.
    a. Tecniche: scansione di rete, ricerca web, accesso a siti della vittima.
2. **Resource Development:** Creazione di risorse per supportare l'attacco.
    a. Tecniche: creazione di infrastrutture di attacco, compromissione di account.
3. **Initial Access:** Ottenere l'accesso iniziale a un sistema bersaglio.
    a. Tecniche: exploit di applicazioni esposte, phishing, utilizzo di dispositivi hardware malevoli.
4. **Execution:** Eseguire codice malevolo sul sistema compromesso.

    a. Tecniche: utilizzo di interpreti già presenti sul sistema, esecuzione di container.

5. **Persistence:** Mantenere l'accesso al sistema nel tempo.
    a. Tecniche: manipolazione di account, attacco ai sistemi di autenticazione, inserimento di componenti nel boot del sistema.
6. **Privilege Escalation:** Ottenere privilegi più elevati sul sistema.
    a. Tecniche: abuso di meccanismi di controllo, exploit di vulnerabilità, injection di processi.
7. **Defense Evasion:** Evitare il rilevamento da parte dei sistemi di sicurezza.
    a. Tecniche: manipolazione di indicatori di compromissione, evasione dei controlli di sicurezza.
8. **Credential Access:** Rubare credenziali di accesso.
    a. Tecniche: attacchi man-in-the-middle, cattura di input, autenticazione forzata.
9. **Discovery:** Esplorare l'ambiente bersaglio per raccogliere informazioni utili.
    a. Tecniche: scoperta di account, software installati, applicazioni in esecuzione.
10. **Lateral Movement:** Spostarsi lateralmente all'interno dell'infrastruttura bersaglio.
    a. Tecniche: exploit di servizi remoti, trasferimento di strumenti tra nodi, attacco a memoria condivisa.
11. **Collection:** Raccogliere dati di interesse.
    a. Tecniche: intercettazione di traffico, registrazione di audio e video.
12. **Command and Control:** Stabilire un canale di comunicazione con il sistema compromesso.
    a. Tecniche: tunneling di protocollo, risoluzione dinamica di domini per offuscare la comunicazione.
13. **Exfiltration:** Rubare dati e trasferirli all'esterno del sistema bersaglio.

    a. Tecniche: esfiltrazione tramite servizi web, rete, dispositivi fisici o cloud.

14. **Impact**: Manipolare, interrompere o distruggere sistemi e dati.
    a. Tecniche: distruzione o cifratura di dati, manipolazione delle informazioni, inibizione dei sistemi di ripristino.

Tecnica: Account Discovery

L'**account discovery** è una tecnica utilizzata dagli attaccanti per identificare account utente, amministrativi o di servizio all'interno di un sistema o rete compromessa. Questa informazione può essere utilizzata per movimenti laterali, escalation di privilegi o per attacchi successivi.

Procedure di Account Discovery

1. **Enumerazione di utenti locali**
   - Utilizzo di comandi di sistema per elencare gli utenti presenti su una macchina compromessa:
     - **Windows**:
       - `net user` → Elenca gli utenti locali
       - `wmic useraccount get name,sid` → Mostra utenti e relativi SID
     - **Linux/macOS**:
       - `cat /etc/passwd` → Elenca utenti locali
       - `id` → Mostra ID dell'utente corrente
       - `who` / `w` → Mostra utenti attivi
2. **Enumerazione di gruppi e privilegi**
   - **Windows**:
     - `net localgroup` → Elenca gruppi locali
     - `net localgroup Administrators` → Elenca utenti con privilegi amministrativi
   - **Linux/macOS**:

- `groups` → Mostra i gruppi di cui fa parte un utente
- `cat /etc/group` → Elenca tutti i gruppi e i rispettivi membri

3. **Enumerazione di account di dominio (Active Directory)**
   - **Windows (in ambiente AD)**:
     - `net user /domain` → Elenca utenti del dominio
     - `dsquery user` → Trova utenti nel dominio
     - `Get-ADUser -Filter *` (PowerShell) → Ottiene tutti gli utenti AD
4. **Enumerazione di utenti attivi su un sistema**
   - **Windows**:
     - `query user` → Mostra utenti loggati
     - `whoami /all` → Mostra privilegi e gruppi dell'utente corrente
   - **Linux/macOS**:
     - `who -a` / `w` / `last` → Mostrano utenti connessi e cronologia accessi
5. **Accesso ai log per scoprire account**
   - **Windows**:
     - `wevtutil qe Security /f:text /c:10 /rd:true /q:"*[System[(EventID=4624)]]"` → Mostra gli ultimi 10 accessi riusciti
   - **Linux/macOS**:
     - `cat /var/log/auth.log | grep "session opened"` → Controlla gli accessi recenti
6. **Attacchi su sistemi cloud e ambienti SaaS**
   - **AWS**:
     - `aws iam list-users` → Elenca gli utenti IAM
   - **Azure**:
     - `az ad user list` → Ottiene gli utenti Azure AD
   - **Google Workspace**:

- `gcloud iam service-accounts list` → Mostra gli account di servizio

Mitigazioni

- **Principio del minimo privilegio**: limitare i permessi degli utenti per evitare che possano enumerare account.
- **Monitoraggio delle attività sospette**: rilevare comandi anomali che indicano tentativi di scoperta di account.
- **Logging e auditing**: abilitare il monitoraggio dei comandi eseguiti e degli accessi agli account.
- **Restrizione degli strumenti di amministrazione**: limitare l'uso di comandi come `net user` o `dsquery` a utenti autorizzati.

Tattica: Privilege Escalation

La **Privilege Escalation** è una tecnica utilizzata dagli attaccanti per ottenere privilegi più elevati su un sistema compromesso. Questo può avvenire sfruttando vulnerabilità, errori di configurazione o credenziali deboli.

Procedure di Privilege Escalation

1. Abuso di meccanismi di elevazione dei privilegi

L'attaccante sfrutta funzionalità di sistema che consentono di eseguire operazioni con privilegi più elevati.

- **Windows**:
  - `runas /user:Administrator cmd.exe` → Esegue un comando con privilegi elevati.
  - `schtasks /create /tn "task" /tr C:\malware.exe /sc once /st 00:00 /ru SYSTEM` → Crea un'attività pianificata con privilegi di SYSTEM.
  - `bypass UAC` → Tecniche per eseguire processi bypassando il Controllo Account Utente.
- **Linux/macOS**:

- `sudo -l` → Mostra i comandi che un utente può eseguire con sudo.
- `su root` → Prova a ottenere una shell root.
- `pkexec /bin/bash` → Usa PolicyKit per eseguire comandi con privilegi elevati.

---

2. Exploitation di vulnerabilità per escalation

L'attaccante sfrutta vulnerabilità note per ottenere privilegi più elevati.

- **Esempi noti:**
  - **Windows**: Exploit come *CVE-2021-34527* (*PrintNightmare*) per eseguire codice arbitrario come SYSTEM.
  - **Linux**: Exploit come *Dirty COW (CVE-2016-5195)* per ottenere accesso root.

---

3. Injection di processi o esecuzione in contesto privilegiato

L'attaccante inietta codice in un processo con privilegi più alti.

- **Windows**:
  - `mimikatz privilege::debug` → Abilita privilegi di debug per accedere ad altri processi.
  - `Process Hollowing` → Sostituisce il codice di un processo legittimo con codice malevolo.
- **Linux/macOS**:
  - `LD_PRELOAD=/tmp/malicious.so command` → Usa *LD_PRELOAD* per iniettare codice in un processo.
  - `ptrace` → Modifica la memoria di un processo in esecuzione per eseguire codice malevolo.

---

4. Escape da macchine virtuali o container

L'attaccante cerca di evadere da un ambiente isolato per ottenere privilegi elevati sull'host.

- **Windows**:

    - Exploit su Hyper-V o Docker per eseguire codice sull'host.
- **Linux/macOS**:
    - `docker run --privileged -v /:/mnt ubuntu chroot /mnt` → Usa un container Docker per ottenere accesso root sull'host.
    - `lxc-attach -n container_name /bin/sh` → Usa LXC per ottenere accesso privilegiato.

---

5. Manipolazione di permessi e configurazioni

L'attaccante modifica permessi per ottenere privilegi elevati.

- **Windows**:
    - `icacls C:\Program.exe /grant Everyone:F` → Modifica i permessi di un file eseguibile.
    - `sc config some_service binPath= "C:\malware.exe"` → Modifica il percorso di un servizio per eseguire codice malevolo.
- **Linux/macOS**:
    - `chmod u+s /bin/bash` → Rende la shell eseguibile con privilegi elevati.
    - `echo "username ALL=(ALL) NOPASSWD:ALL" >> /etc/sudoers` → Aggiunge un utente con accesso root senza password.

Mitigazioni

- **Patch e aggiornamenti**: correggere vulnerabilità note per evitare exploit.
- **Restrizioni nei permessi**: impedire modifiche non autorizzate a servizi o file sensibili.
- **Monitoraggio e logging**: rilevare tentativi sospetti di escalation.
- **Controllo degli accessi**: applicare il principio del minimo privilegio.
- **Sandboxing e isolamento**: impedire escape da container o macchine virtuali.

Le *MITRE ATT&CK Matrices* rappresentano il framework che descrive le tattiche, tecniche e procedure (TTPs) utilizzate dagli avversari in vari tipi di attacchi informatici.

Ogni matrice è focalizzata su un tipo specifico di sistema o ambiente, come la *Enterprise Matrix* (per infrastrutture complesse), *Cloud*, *Mobile*, *ICS* (Industrial Control Systems), e altre.

Le matrici aiutano a mappare le azioni degli avversari durante l'intero ciclo di vita di un attacco, permettendo agli analisti di comprendere meglio i metodi di intrusione, rilevazione e mitigazione.

Le 10 principali tecniche MITRE ATT&CK (Top 10)

1. **Phishing** (Initial Access): Una delle tecniche più comuni per ottenere accesso iniziale, sfruttando l'ingegneria sociale.
2. **Exploitation of Vulnerabilities** (Privilege Escalation): Sfruttamento di vulnerabilità per ottenere permessi più elevati.
3. **Command and Scripting Interpreter** (Execution): Uso di interpreti per eseguire codice maligno, come PowerShell.
4. **Credential Dumping** (Credential Access): Estrazione di credenziali di accesso da sistemi vulnerabili.
5. **Application Layer Protocols** (Command & Control): Uso di protocolli standard (HTTP, DNS) per comunicare con i sistemi compromessi.
6. **Process Injection** (Defense Evasion): Iniezione di codice maligno nei processi legittimi per eludere i controlli di sicurezza.
7. **Exfiltration Over Web Services** (Exfiltration): Raccogliere e trasferire dati sensibili attraverso servizi web.
8. **Persistence through Reboot** (Persistence): Tecniche per mantenere l'accesso persistente anche dopo un riavvio del sistema.
9. **Lateral Movement** (Discovery): Sfruttare vulnerabilità per muoversi lateralmente tra i sistemi della rete compromessa.
10. **Impact - Data Encryption** (Impact): Criptazione dei dati come parte di un attacco di ransomware.

Comportamenti osservati negli attacchi recenti

- I **campioni di malware** ora contengono una media di 14 azioni dannose, il che li rende più complessi e capaci di eseguire più fasi nel ciclo di vita dell'attacco.
- Le tattiche di **esfiltrazione** e di evasione delle difese rappresentano una parte significativa delle azioni dannose. Gli attaccanti stanno preferendo metodi più furtivi per esfiltrare dati, come l'uso di comunicazioni cifrate (HTTPS, DoH) e tecniche che sfruttano gli strumenti legittimi, come l'iniezione di processi, per rimanere nascosti.
- Non ci sono evidenze che suggeriscano l'uso di **malware guidato dall'IA** da parte dei criminali informatici, nonostante l'hype sulle applicazioni dell'IA nella cybersecurity.

Command & Control (C&C) Infrastructure

- La *Pre Attack Matrix* si concentra sulle azioni degli attaccanti per preparare un'intrusione, come la creazione di infrastrutture di comando e controllo (C&C).
- La creazione di **botnet** per costruire una C&C è semplificata da sistemi a bassa sicurezza, creando così punti vulnerabili da sfruttare.
- Le tecniche per la creazione di C&C sono meno rumorose rispetto agli attacchi veri e propri per ridurre il rischio di rilevamento.

MITRE ATLAS (Adversarial Threat Landscape for AI Systems)

- Questo framework si concentra sulle **vulnerabilità nei sistemi abilitati dall'intelligenza artificiale (AI)**, che stanno aumentando con l'integrazione dell'AI in più sistemi.
- Le tecniche di attacco in ATLAS sono complementari a quelle di ATT&CK, ma sono specifiche per i sistemi AI, coprendo attacchi come l'*evasion del modello*, *poisoning dei dati* e *inversione del modello*.
- I **Machine Learning Attacks** includono:
    - **Model Evasion**: Gli attaccanti manipolano le query per ottenere risultati desiderati.

- **Model Poisoning**: Manipolazione dei dati di addestramento per inserire backdoor nel modello.
- **Model Inversion**: Attacco che consente agli avversari di ottenere informazioni private attraverso l'analisi di un modello addestrato.